COMPTIA SECURITY+ SY0-701 DOMÍNIO 1 · CONCEITOS GERAIS DE SEGURANÇA (12%)

Security+ 1.2 · Deception & Disruption

Mestre CyberSec · **Aula 1.2 — Deception & Disruption** (4:30) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Isca e engana: honeypot (máquina falso), honeynet (rede de honeypots), honeyfiles (arquivo-isca), DNS sinkhole (redireciona domínio malicioso pra nada), false azure (serviço que finge ser cloud). Detecta e estuda o atacante.

💡 Highlights que a prova CompTIA cobra

- Honeypot = alvo falso: parece real, é monitorado
- Honeyfile: documento-isca com beacon — dispara alerta ao abrir
- DNS sinkhole = envia C2 pra IP nulo e LOGA quem tentou

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'appears vulnerable but is monitored' = honeypot
- 'redirects malicious domain traffic' = sinkhole

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 1.2 — Deception & Disruption)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Honeypot (Armadilha) (N/A)

Um sistema ou serviço isca projetado para atrair atacantes, detectar acesso não autorizado e coletar inteligência de ameaças sem expor ativos reais.

⚠️ ***Armadilha CompTIA:*** *Lembre-se: honeypot é uma isca, não um sistema de produção. Se um atacante interage com ele, é quase certo que seja um ataque. Diferencie de honeynet (rede de honeypots) e honeyfile (arquivo isca).*

• Honeynet (Rede de Honeypots) (N/A)

Uma rede de múltiplos honeypots projetada para simular uma rede real, permitindo aos defensores observar o comportamento do atacante em um ambiente maior.

⚠️ ***Armadilha CompTIA:*** *Honeynet é uma coleção de honeypots. Não confunda com um único honeypot. É mais realista e pode enganar atacantes por mais tempo.*

• Honeyfile (Arquivo Isca) (N/A)

Um arquivo isca colocado em um sistema ou rede para atrair atacantes; qualquer acesso ou modificação dispara um alerta, frequentemente usado para detectar ameaças internas ou hosts comprometidos.

⚠️ ***Armadilha CompTIA:*** *Honeyfile é um arquivo, não um sistema. Se um usuário legítimo acessa, pode indicar comprometimento. Foco em detecção, não em prevenção.*

• DNS Sinkhole (Poço de DNS)

Um servidor DNS que retorna um endereço IP não roteável ou falso para domínios maliciosos conhecidos, impedindo o acesso e identificando hosts infectados que tentam resolvê-los.

⚠️ ***Armadilha CompTIA:*** *DNS sinkhole redireciona domínios maliciosos para um endereço controlado, bloqueando a comunicação C2 e revelando máquinas infectadas. Não é um firewall.*

• Telemetria Falsa (N/A)

Uma técnica de enganação que fornece dados falsos de sistema, rede ou aplicação para atacantes, enganando-os sobre o ambiente e atrasando suas ações.

⚠️ ***Armadilha CompTIA:*** *Fake telemetry é sobre fornecer informações falsas, não apenas um honeypot. Pode incluir arquivos, registros, tráfego de rede falsos. Distinga de honeypot (sistema isca).*

• Tarpit (Poço de Alcatrão) (N/A)
Um serviço de segurança que atrasa ou paralisa deliberadamente conexões de atacantes para consumir seus recursos e retardar ataques automatizados.

⚠️ ***Armadilha CompTIA:*** *Tarpit é uma técnica de disrupção, não de detecção. Ele atrasa o atacante, enquanto honeypot o engana. Pode ser usado para combater worms e bots.*

• False Azure (Serviço de Nuvem Falso) (N/A)
Um serviço de nuvem enganoso que imita uma plataforma de nuvem legítima (ex.: Microsoft Azure) para atrair atacantes, coletar inteligência e desviar a atenção de ativos reais na nuvem.

⚠️ ***Armadilha CompTIA:*** *False Azure é um exemplo de honeypot em nuvem. Se a prova mencionar 'serviço que finge ser nuvem', pense em honeypot ou fake cloud. Não confunda com fake telemetry.*

• Tecnologia de Enganação (N/A)
Controles de segurança que usam iscas, armadilhas e informações falsas para enganar atacantes, detectar intrusões e coletar inteligência de ameaças.

⚠️ ***Armadilha CompTIA:*** *Deception technology é o conceito guarda-chuva que inclui honeypot, honeynet, honeyfile, fake telemetry, etc. O objetivo é detectar e estudar o atacante, não apenas bloquear.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Honeypot vs. Honeynet vs. Honeyfile

🏠 **Analogia Intuitiva:** O Honeypot é um cofre falso com uma nota de 100 reais falsa colocada no meio da sala só para ver quem tenta roubar. O Honeynet é a réplica falsa do banco inteiro. O Honeyfile é um arquivo com nome 'senhas_bancarias.xlsx' que ninguém na empresa usa, mas que dispara um alarme no segundo em que alguém clica nele.

🔍 **Causa Raiz / Por que foi criado:** Atacantes vasculham a rede procurando alvos fáceis; armadilhas detectam movimentos laterais antes que cheguem a dados reais.

🛡️ **Visão do Auditor de GRC:** Garantir isolamento absoluto da rede de produção para que o honeypot não seja usado pelo invasor como ponto de salto.

⚠️ **Como cai na Prova CompTIA:** Trigger: 'decoy server to gather attacker telemetry' -> Honeypot. 'Fake file triggering alert upon access' -> Honeyfile / Honeytokan.

📌 DNS Sinkhole

🏠 **Analogia Intuitiva:** É como a polícia interceptar cartas destinadas ao esconderijo dos bandidos e redirecioná-las para a delegacia central sem que os comparsas saibam.

🔍 **Causa Raiz / Por que foi criado:** Computadores infectados tentam falar com servidores de Comando e Controle (C2). O Sinkhole altera a resposta de DNS para que a máquina fale com um servidor seguro de análise.

🛡️ **Visão do Auditor de GRC:** Auditar os registros de sinkholing do DNS interno para identificar computadores infectados que precisam de quarentena imediata.

⚠️ **Como cai na Prova CompTIA:** Trigger: 'redirecting malicious domain queries to a controlled internal IP' -> DNS Sinkhole.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Servidor chamariz configurado para atrair e registrar táticas de invasores	**Honeypot**
Arquivo falso com isca para alertar quando houver vazamento interno	**Honeyfile / Honeydoken**
Redirecionar consultas a servidores maliciosos de C2 para um servidor seguro de análise	**DNS Sinkhole**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Durante um surto de malware, estações de trabalho infectadas tentam resolver domínios de comando e controle (C2). Os engenheiros configuram os servidores DNS internos para responder consultas desses domínios maliciosos com o IP de loopback local, cortando a comunicação e registrando os IPs dos clientes infectados. Qual técnica foi utilizada?

A) DNS Sinkhole (Sumidouro DNS)

B) Split-horizon DNS

C) Assinatura de zona DNSSEC

D) Dynamic DNS (DDNS)

QUESTÃO 2 · CENÁRIO DE EXAME

Um administrador de sistemas percebe um scanner automatizado realizando ataques de força bruta massivos contra a porta SSH pública. Para esgotar as conexões do atacante e desacelerar o ataque, o firewall aceita a conexão TCP mas transmite dados intencionalmente byte a byte com atrasos extremos. Qual mecanismo de disrupção é este?

A) Tarpit (Poço de piche / atraso de conexão)

B) Rate limiting convencional

C) Inspeção de pacotes com estado (Stateful inspection)

D) Firewall de Aplicação Web (WAF)

QUESTÃO 3 · CENÁRIO DE EXAME

Para confundir agentes de ameaça durante o reconhecimento e enganar scanners de vulnerabilidade automatizados, uma equipe de segurança configura serviços para responder com banners de sistema operacional falsificados e respostas sintéticas de portas abertas. Qual conceito de decepção isso ilustra?

A) Telemetria falsa (Fake telemetry)

B) Encaminhamento de portas (Port forwarding)

C) Captura de pacotes (Packet sniffing)

D) Tradução de Endereços de Rede (NAT)

QUESTÃO 4 · CENÁRIO DE EXAME

Uma corporação implanta um cluster distribuído de servidores isca, roteadores simulados e controladores de domínio Active Directory falsos em uma sub-rede isolada para observar movimentos laterais de invasores. Como esse ambiente de decepção é classificado?

A) Honeynet (Rede de Iscas)

B) Zona Desmilitarizada (DMZ)

C) Sub-rede de produção em Air-gap

D) Sub-rede de bastiões

QUESTÃO 5 · CENÁRIO DE EXAME

Um engenheiro de DevOps cria uma chave de acesso AWS IAM fictícia sem nenhuma permissão real e a insere em um repositório Git interno. Se qualquer chamada de API for tentada com essa chave, o SIEM dispara um alerta crítico de vazamento de código. Como essa credencial isca é chamada?

A) Honeytoken (Token / Credencial Isca)

B) Cookie de sessão persistente

C) Certificado digital X.509

D) JSON Web Token (JWT)

QUESTÃO 6 · CENÁRIO DE EXAME

De acordo com os objetivos do exame CompTIA Security+ SY0-701, qual é o objetivo defensivo primordial ao implantar tecnologias de decepção (como honeypots e honeyfiles)?

A) Desviar, atrasar e coletar inteligência acionável sobre as metodologias do atacante

B) Substituir permanentemente firewalls de borda e sistemas de prevenção de intrusão

C) Formatar e desinfetar automaticamente discos rígidos sem intervenção humana

D) Garantir não-repúdio criptográfico para todo o tráfego de e-mail de saída

QUESTÃO 7 · CENÁRIO DE EXAME

Ao implantar um honeypot de alta interação exposto diretamente na Internet pública, qual é o maior risco operacional que os engenheiros de segurança devem isolar e mitigar?

A) O honeypot ser comprometido e usado como ponto de pivô/salto para atacar outros sistemas

B) Consumo excessivo de CPU causado por acessos de funcionários legítimos

C) Esgotamento da faixa de endereços IPv4 privados internos da empresa

D) Incompatibilidade com os algoritmos de criptografia do protocolo TLS 1.3

QUESTÃO 8 · CENÁRIO DE EXAME

Um arquiteto de segurança está projetando uma implantação de honeynet e precisa de um gateway especializado para monitorar, limitar a taxa e filtrar o tráfego de saída da rede isca, evitando que ataques partam do honeypot. Como esse dispositivo é chamado?

A) Honeywall

B) Cache de proxy direto

C) Balanceador de carga (Load Balancer)

D) Tradutor de Endereços de Rede (NAT)

QUESTÃO 9 · CENÁRIO DE EXAME

Uma equipe de operações de segurança quer estudar as táticas, técnicas e procedimentos (TTPs) de atacantes que visam servidores de banco de dados Linux, sem arriscar registros reais de clientes. Eles implantam um servidor isca isolado com dados fictícios e telemetria ativa. Qual controle foi implementado?

A) Honeypot (Sistema Isca)

B) Bastion host

C) Proxy direto (Forward proxy)

D) Zona Desmilitarizada (DMZ)

QUESTÃO 10 · CENÁRIO DE EXAME

Uma organização suspeita que um insider mal-intencionado está tentando vazar planilhas confidenciais de folha de pagamento da diretoria. Um engenheiro de segurança coloca uma planilha com o nome 'Q4_Salarios_Diretoria.xlsx' contendo um web beacon invisível no servidor de arquivos. Qual controle de decepção isso descreve?

A) Honeyfile (Arquivo Isca)

B) Honeynet (Rede Isca)

C) DNS Sinkhole (Sumidouro DNS)

D) Monitoramento de Integridade de Arquivos (FIM)

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — DNS Sinkhole (Sumidouro DNS)

O DNS Sinkhole intercepta consultas DNS para domínios maliciosos conhecidos e responde com um IP falso ou de monitoramento, impedindo a comunicação com o servidor C2 e identificando máquinas infectadas.

Questão 2: Alternativa A — Tarpit (Poço de piche / atraso de conexão)

O Tarpit aceita conexões TCP mas responde de forma deliberadamente lenta (byte a byte), prendendo as conexões do atacante e esgotando os recursos de seus scanners e bots automatizados.

Questão 3: Alternativa A — Telemetria falsa (Fake telemetry)

A telemetria falsa injeta banners, dados de portas e respostas simuladas propositalmente incorretas, induzindo o atacante a usar exploits incompatíveis e perdendo tempo valioso.

Questão 4: Alternativa A — Honeynet (Rede de Iscas)

Uma Honeynet é uma rede inteira composta por múltiplos honeypots e serviços simulados interconectados, permitindo analisar ataques complexos com movimentação lateral em escala de rede.

Questão 5: Alternativa A — Honeytoken (Token / Credencial Isca)

Um Honeytoken é um dado ou credencial isca (como chaves de API, senhas ou e-mails falsificados) que não possui função legítima; qualquer tentativa de uso indica imediatamente comprometimento.

Questão 6: Alternativa A — Desviar, atrasar e coletar inteligência acionável sobre as metodologias do atacante

O objetivo fundamental das tecnologias de decepção é desviar os invasores dos ativos críticos reais, ganhar tempo (atrasar) e coletar inteligência estratégica sobre as táticas do inimigo.

Questão 7: Alternativa A — O honeypot ser comprometido e usado como ponto de pivô/salto para atacar outros sistemas

Em honeypots de alta interação (sistemas operacionais reais), o invasor ganha controle da máquina; sem isolamento estrito (Honeywall), ele pode usar o honeypot como trampolim (pivot) para atacar outros alvos.

Questão 8: Alternativa A — Honeywall

Uma Honeywall é um gateway/firewall especializado posicionado na frente da honeynet que intercepta e controla o tráfego, garantindo contenção estrita para que o honeypot não ataque terceiros.

Questão 9: Alternativa A — Honeypot (Sistema Isca)

Um honeypot é um sistema isca projetado para parecer vulnerável e atrair invasores, permitindo registrar suas técnicas de ataque sem colocar em risco ativos reais de produção.

Questão 10: Alternativa A — Honeyfile (Arquivo Isca)

Um honeyfile é um arquivo isca atrativo colocado em compartilhamentos de rede com sinalizadores internos que disparam alertas imediatos ao SOC no instante em que é aberto ou transferido.